

AI Security and Access Control Policy

MT&T Corporation - Effective Date: January 1, 2026

Classification: INTERNAL - CONFIDENTIAL

Document Version: 2.1 | Last Updated: March 15, 2026

1. Purpose

This policy defines the security controls and access management requirements for AI systems within MT&T Corporation. It addresses authentication, authorization, network security, data protection, and incident response specific to AI/ML workloads on the Databricks platform.

2. Authentication Requirements

All AI platform access must use federated authentication through MT&T's enterprise identity provider (Azure AD/Okta). Multi-factor authentication is required for all human users accessing AI resources. Service principals must use OAuth machine-to-machine tokens with automatic rotation every 90 days.

Personal access tokens (PATs) are prohibited for production AI workloads. Development environments may use PATs with a maximum lifetime of 7 days and must be rotated automatically.

3. Authorization Framework

Access to AI resources follows a role-based access control (RBAC) model with the following roles: AI Platform Admin - Full access to all AI resources, endpoint management, and governance views. Model Owner - Manage specific serving endpoints, view usage metrics, configure alerts. Model Consumer - Invoke serving endpoints, view Genie rooms, access AI Gateway. AI Auditor - Read-only access to all governance views, audit logs, and cost reports. Data Scientist - Access to model training resources, experiment tracking, and development endpoints.

Unity Catalog fine-grained access controls must be applied to all AI-related tables, views, and models. Row-level and column-level security must be implemented for views containing sensitive user or cost data.

4. Unauthorized Access Detection

The `v_ai_access_audit` view must be monitored continuously for unauthorized access patterns. The following events trigger automated alerts and investigation: Any request resulting in HTTP 401 (Unauthorized) or 403 (Forbidden) response, More than 5 denied access attempts from a single user within 1 hour, Access attempts to decommissioned endpoints, Access from IP addresses outside MT&T's approved network ranges, Service principal access from unexpected workspaces.

The Security Operations Center (SOC) must investigate all high-severity alerts within 4 hours. Confirmed unauthorized access attempts must be reported to the CISO within 24 hours.

5. AI Gateway Security Controls

All external-facing AI endpoints must be routed through Databricks AI Gateway. Required AI Gateway configurations: Rate limiting - Maximum 100 requests per minute per user for chat endpoints, Content filtering - Block PII, hate speech, and harmful content in both input and output, Token limits - Maximum 4096 input tokens and 2048 output tokens per request for standard users, Fallback routing - Primary and fallback model destinations with automatic failover.

AI Gateway usage is tracked via the `v_ai_gateway_daily` view. The security team must review `destination_model` distribution weekly to ensure only approved models are being accessed.

6. Network Security

Model serving endpoints handling Confidential or Restricted data must use private endpoints (AWS PrivateLink). Public endpoint access requires IP allowlisting. All AI platform traffic must traverse MT&T's security inspection infrastructure. VPC peering for cross-workspace AI data flows must be approved by the Network Security team.

7. Incident Response

AI-specific security incidents include: Data exfiltration through model serving responses, Prompt injection attacks on foundation model endpoints, Unauthorized model deployment or modification, AI Gateway bypass attempts, Anomalous token consumption indicating abuse.

The AI Security Incident Response Plan (AI-SIRP) must be followed for all AI-related incidents. The plan is maintained by the CISO office and reviewed quarterly. Post-incident reviews must include analysis of system table data to identify root cause and prevention measures.